CRISC Domain C - 100 More Very Hard Questions

Risk Response and Reporting - Expert Level (Part 3)

CRISC Mastery Series

October 21, 2026

Outline

1. 1. Risk Response Strategies - Expert
2. 2. Risk and Control Ownership - Expert
3. 3. Third-Party Risk Management - Expert
4. 4. Control Design and Implementation - Expert
5. 5. Monitoring and Reporting - Expert

Q201: Multi-Risk Response Interaction

Question

A risk response for Risk A creates a new secondary risk. The secondary risk is assessed as high. What should happen?

A. Ignore secondary risk - focus on primary risk

B. Assess and treat secondary risk as a new risk

C. Revert the original risk response

D. Transfer the secondary risk

Q201: Explanation

Correct Answer: B

Secondary risks must be assessed and treated:

- Secondary risk = new risk created by risk response
- Must be entered into risk register
- Assessed for likelihood and impact
- Treated like any other risk

Critical Trap

Risk response can create new risks. Always assess secondary risks.

Q202: Risk Response Cost-Benefit Edge Case

Question

A control costs $100K and reduces risk from $150K to $60K. However, the risk has only 10% likelihood. Should the control be implemented?

A. Yes, because residual risk is lower

B. No, because expected loss reduction is less than control cost

C. Yes, because risk exceeds appetite

D. Cannot determine

Q202: Explanation

Correct Answer: B

Calculation:

- Expected loss before = 10% × $150K = $15K
- Expected loss after = 10% × $60K = $6K
- Risk reduction = $9K
- Control cost = $100K
- $100K ¿ $9K = NOT justified

Critical Trap

Use expected loss (likelihood × impact), not just impact.

Q203: Risk Avoidance Hidden Risk

Question

A company avoids a risk by discontinuing a product. What hidden risk does this create?

A. No hidden risk
B. Reputational risk from abandoning customers
C. Lower insurance costs
D. Increased market share

Q203: Explanation

Correct Answer: B

Avoidance creates reputational risk:

- Customers may feel abandoned
- Brand damage from discontinuation
- Competitors may exploit
- Employee morale impact

Critical Trap

Avoidance is not "free" - it has hidden costs.

Q204: Transfer Residual Accountability

Question

An organization transfers risk through insurance. A claim is denied. Who bears the loss?

A. Insurance company
B. Original organization
C. Both equally
D. No one

Q204: Explanation

Correct Answer: B

Original organization bears loss:

- Transfer is only as good as the contract
- Denied claims = no transfer
- Organization retains risk
- Need to understand exclusions

Critical Trap

Transfer is conditional on claim approval. Read the fine print.

Q205: Risk Acceptance Authority Limits

Question

A risk owner has authority to accept risks up to $100K. A risk is assessed at $150K. What should happen?

A. Risk owner accepts - they own the risk
B. Escalate to higher authority
C. Accept partially
D. Ignore the limit

Q205: Explanation

Correct Answer: B

Escalate:

- Authority limits are defined
- $150K ¿ $100K limit
- Higher authority required
- Board or executive approval

Critical Trap

Risk owners have defined authority limits. Know and respect them.

Q206: Mitigation Implementation Delay

Question

A control takes 6 months to implement. The risk has 80% likelihood and $500K impact. What is the risk during implementation?

A. No risk
B. $200K expected loss
C. $400K expected loss
D. $500K expected loss

Q206: Explanation

Correct Answer: B

Calculation:

- Expected annual loss = 80% × $500K = $400K
- During 6 months = $400K × 0.5 = $200K
- Risk continues during implementation

Critical Trap

Implementation period = Continued exposure. Consider interim controls.

Q207: Compensating Control Equivalence

Question

A compensating control is proposed. What must it provide to be acceptable?

A. Lower cost

B. Equivalent or superior risk reduction

C. Automated solution

D. IT approval

Q207: Explanation

Correct Answer: B

Equivalent or superior risk reduction:

- Must address the same risk
- Must reduce to acceptable level
- Cost is secondary
- Effectiveness is primary

Critical Trap

Compensating control = Same risk reduction. Cheaper but less effective = Not acceptable.

Q208: Risk Response Documentation Contents

Question

What should a risk response plan document include?

A. Only the response type

B. Response, owner, timeline, cost, expected outcome

C. Only the cost

D. Only the timeline

Q208: Explanation

Correct Answer: B

Comprehensive documentation:

- Response type (mitigate/accept/transfer/avoid)
- Risk owner
- Implementation timeline
- Cost of response
- Expected residual risk
- Success metrics

Critical Trap

Documentation must be comprehensive to be defensible.

Q209: Risk Transfer Contract Clause

Question

Which clause is MOST important in a risk transfer contract?

- A Payment terms
- B Indemnification and limitation of liability
- C Termination clause
- D Renewal terms

Q209: Explanation

Correct Answer: B

Indemnification and limitation of liability:

- Defines what risk is transferred
- Specifies financial responsibility
- Limits liability exposure
- Critical for risk transfer

Critical Trap

Without indemnification, transfer is incomplete.

Q210: Avoidance vs Acceptance Trap

Question

A company decides not to pursue a risky project. This is:

- A Acceptance of opportunity cost
- B Avoidance of project risk
- C Mitigation of risk
- D Transfer of risk

Q210: Explanation

Correct Answer: B

Avoidance:

- Not doing the activity that creates risk
- Eliminates project risk
- Creates opportunity cost risk
- Valid risk response

Critical Trap

Not doing something = Avoidance. Doing something = Other responses.

Q211: Risk Owner Conflict Resolution

Question

Two business units claim ownership of a shared risk. Neither wants responsibility. What should happen?

A. Split 50/50

B. Assign to larger BU

C. Escalate to senior management for single owner

D. Leave unowned

Q211: Explanation

Correct Answer: C

Escalate for single ownership:

- Shared ownership = No accountability
- Senior management assigns authority
- Owner must have cross-functional authority
- May need C-level assignment

Critical Trap

Multiple owners = No owner. Single accountability required.

Q212: Control Owner Without Budget

Question

A control owner identifies a failing control but has no budget. What should they do FIRST?

- A Document and escalate to risk owner
- B Implement compensating control
- C Accept risk
- D Wait for audit

Q212: Explanation

Correct Answer: A

Escalate to risk owner:

- Risk owner has budget authority
- Risk owner accountable
- Control owner documents
- Control owner recommends

Critical Trap

Control ownerno equal Budget authority. Escalate for resources.

Q213: Risk Owner Delegation

Question

A risk owner delegates authority without documentation. What is the risk?

A. No risk
B. Subordinate cannot be held accountable
C. Owner remains accountable but delegate has no authority
D. Both B and C

Q213: Explanation

Correct Answer: D

Documentation required:

- Delegate cannot make binding decisions
- Owner remains accountable
- No clear authority chain
- Audit trail broken

Critical Trap

Delegation must be documented and communicated.

Q214: Multiple Controls One Owner

Question

A control owner is responsible for 50 controls. What is the PRIMARY risk?

A. Too much work

B. Controls may not receive adequate attention

C. Higher salary

D. Needs training

Q214: Explanation

Correct Answer: B

Span of control risk:

- 50 controls is too many
- Some controls neglected
- Testing insufficient
- Effectiveness degrades

Critical Trap

Too many controls = Diluted oversight.

Q215: Risk Owner Absence

Question

A critical risk decision is needed but the risk owner is on vacation. What should happen?

A. Wait for return
B. Control owner decides
C. Designated alternate with documented authority
D. Cannot decide

Q215: Explanation

Correct Answer: C

Designated alternate:

- Risk owner designates alternate
- Documented authority
- Alternate understands risk
- Business continuity

Critical Trap

No alternate = Decision paralysis. Always designate alternate.

Q216: Risk Owner vs Control Owner

Question

Risk owner wants to accept risk. Control owner insists on remediation. Who decides?

A. Risk owner
B. Control owner
C. Senior management - escalate
D. Budget holder

Q216: Explanation

Correct Answer: C

Escalate:

- Conflict indicates unresolved issues
- Senior management perspective
- Balance risk and control
- Document decision

Critical Trap

Conflicts require escalation. Risk owner not unilateral.

Q217: IT Risk Owner

Question

Who should be risk owner for data breach risk?

A. CISO
B. CIO
C. Business leader who owns data
D. IT manager

Q217: Explanation

Correct Answer: C

Business leader owns risk:

- Data is business asset
- Breach impacts business
- Budget authority
- IT/CISO are enablers

Critical Trap

IT does NOT own business risk. Data owner = Risk owner.

Q218: Control Testing Responsibility

Question

Who is responsible for testing controls?

A. Risk owner
B. Control owner
C. Internal audit
D. External auditor

Q218: Explanation

Correct Answer: B

Control owner:

- Responsible for effectiveness
- Testing verifies
- Internal audit independent
- External audit external

Critical Trap

Control owner = First line of testing. Audit = Independent verification.

Q219: Risk Owner Budget

Question

A risk owner lacks budget for controls. What is the consequence?

A. Nothing
B. Risk cannot be effectively managed
C. Control owner pays
D. Risk transferred

Q219: Explanation

Correct Answer: B

No budget = No risk management:

- Controls cannot be implemented
- Risk unmanaged
- Owner ineffective
- Escalation needed

Critical Trap

Risk ownership requires budget authority.

Q220: Risk Owner Rotation

Question

Should risk ownership rotate periodically?

A. Yes, for objectivity

B. No, ownership should be stable

C. Depends on requirements

D. Only for IT risks

Q220: Explanation

Correct Answer: B

Ownership should be stable:

- Continuity of knowledge
- Accountability maintained
- Stakeholder relationships
- Long-term perspective

Critical Trap

Risk owner turnover = Loss of continuity.

Q221: Vendor Assessment Scope

Question

A vendor has SOC 2 Type II. Can you rely on it for all services?

- A Yes
- B No, only scoped services
- C Yes if recent
- D No, unreliable

Q221: Explanation

Correct Answer: B

Scope limitation:

- Report covers specific services
- Out-of-scope needs assessment
- Check scope first
- Request expansion

Critical Trap

SOC 2no equal All services. Scope matters.

Q222: Fourth-Party Risk

Question

Your vendor uses subcontractor. Subcontractor breach. Who is liable?

A. Only subcontractor
B. You and vendor
C. Only you
D. Only vendor

Q222: Explanation

Correct Answer: B

Multiple parties:

- You: Regulatory accountability
- Vendor: Contractual responsibility
- Subcontractor: Direct liability
- Fourth-party risk affects you

Critical Trap

Fourth-party breach = Your problem too.

Q223: Vendor Offboarding

Question

What is GREATEST risk during vendor offboarding?

A. Service disruption

B. Data remanence

C. Cost

D. Knowledge loss

Q223: Explanation

Correct Answer: B

Data remanence:

- Data on vendor systems
- Backups not deleted
- Regulatory violations
- Reputational damage

Critical Trap

Offboarding = Data destruction priority. Require certificate of destruction.

Q224: Vendor Contract

Question

Which clause is MOST important for data protection?

- A SLA
- B Right to audit + security requirements
- C Indemnification
- D NDA

Q224: Explanation

Correct Answer: B

Right to audit + security requirements:

- Ongoing verification
- Minimum standards
- Recourse if unmet
- Prevention ¿ compensation

Critical Trap

Prevention ¿ Compensation.

Q225: Vendor Assessment Timing

Question

When should vendor assessment occur?

- A Before contract
- B After contract
- C After go-live
- D Annually

Q225: Explanation

Correct Answer: A

Before contract:

- Negotiate security
- Informed decision
- Identify deal-breakers
- Leverage improvements

Critical Trap

Assessment after contract = No leverage.

Q226: Vendor Monitoring Frequency

Question

How often should vendor risk be reassessed?

A. Only at renewal

B. Annually or when changes occur

C. Every 3 years

D. Only on breach

Q226: Explanation

Correct Answer: B

Annual or event-driven:

- Annual minimum
- When services change
- When incident occurs
- When regulations change

Critical Trap

Vendor risk is not static. Annual reassessment required.

Q227: Vendor Exception

Question

Vendor requests policy exception. What should happen?

A. Approve automatically
B. Evaluate risk and require compensating controls
C. Deny all
D. Ignore

Q227: Explanation

Correct Answer: B

Evaluate and compensate:

- Understand need
- Assess risk
- Require compensating controls
- Document and review

Critical Trap

Exceptions are not automatic.

Q228: Vendor Incident Notification

Question

How quickly should vendor notify of breach?

A. 30 days

B. 24-72 hours

C. 1 week

D. At discretion

Q228: Explanation

Correct Answer: B

24-72 hours:

- Regulatory requirements (GDPR: 72 hours)
- Contract specifies
- Time to respond
- Time to notify regulators

Critical Trap

Delayed notification = Delayed response.

Q229: Vendor Data Location

Question

Vendor stores data in foreign country. PRIMARY concern?

A. Latency
B. Regulatory and legal jurisdiction
C. Cost
D. Language

Q229: Explanation

Correct Answer: B

Jurisdiction issues:

- Laws vary by country
- GDPR, CCPA apply
- Law enforcement access
- Legal process difficult

Critical Trap

Data location = Legal jurisdiction.

Q230: Vendor Subcontractor Approval

Question

Should vendor require approval for subcontractors?

A. No

B. Yes, for visibility of fourth-party risk

C. Only different country

D. Only critical services

Q230: Explanation

Correct Answer: B

Approval required:

- Know who handles data
- Fourth-party risk assessed
- Object to subcontractors
- Maintain accountability

Critical Trap

Unknown subcontractors = Unmanaged risk.

Q231: Warning Banner Control

Question

A warning banner on login page is what control?

- A Preventive
- B Detective
- C Deterrent
- D Corrective

Q231: Explanation

Correct Answer: C

Deterrent:

- Warns of consequences
- Doesn't block (preventive)
- Doesn't detect (detective)
- Discourages through fear

Critical Trap

Warning = Deterrent. Discourages, doesn't prevent.

Q232: IDS with Auto-Block

Question

IDS detects and blocks. Detective or corrective?

A. Detective only
B. Corrective only
C. Both
D. Preventive

Q232: Explanation

Correct Answer: C

Both:

- Detection = Detective
- Blocking = Corrective
- Modern systems combine
- Analyze actions

Critical Trap

Controls can have multiple functions.

Q233: Compensating Control Requirement

Question

Compensating control must provide:

A. Cheaper solution
B. Equivalent risk reduction
C. Automated
D. IT-approved

Q233: Explanation

Correct Answer: B

Equivalent risk reduction:

- Address same risk
- Reduce to acceptable
- Cost secondary
- Effectiveness primary

Critical Trap

Compensating = Same risk reduction.

Q234: Control Testing Frequency

Question

How often should controls be tested?

- A Annually all
- B Based on risk
- C Only changes
- D Quarterly all

Q234: Explanation

Correct Answer: B

Risk-based:

- High-risk more frequent
- Low-risk less frequent
- Regulatory requirements
- Change frequency

Critical Trap

One size does NOT fit all.

Q235: Operating Deficiency

Question

Control designed correctly but not operating. This is:

A. Design deficiency
B. Operating deficiency
C. Gap
D. Redundancy

Q235: Explanation

Correct Answer: B

Operating deficiency:

- Design correct
- Operation failing
- Personnel, process, technology
- Focus operation

Critical Trap

Design correct, operation failing = Operating.

Q236: Parallel Changeover Risk

Question

PRIMARY risk of parallel changeover?

A. Failure
B. Data inconsistency
C. Resistance
D. Cost

Q236: Explanation

Correct Answer: B

Data inconsistency:

- Both process transactions
- Data not sync
- Reconciliation complex
- Errors undetected

Critical Trap

Parallel = Safe availability, risky consistency.

Q237: Abrupt Changeover

Question

When is abrupt acceptable?

A. Critical systems
B. Minor changes, easy rollback
C. Users trained
D. Vendor recommends

Q237: Explanation

Correct Answer: B

Minor, reversible:

- Low impact
- Quick recovery
- No critical processes
- Acceptable risk

Critical Trap

Abrupt = Fastest but highest risk.

Q238: Post-Implementation Review

Question

When should review occur?

A. Immediately
B. After stabilization
C. Only issues
D. Before audit

Q238: Explanation

Correct Answer: B

After stabilization (3-6 months):

- Issues surfaced
- Meaningful feedback
- Performance assessed
- Lessons learned

Critical Trap

Wait for stability.

Q239: Automated Control Monitoring

Question

Automated control eliminates monitoring?

A. Yes
B. No, can fail
C. Yes, no errors
D. No, reduced

Q239: Explanation

Correct Answer: B

Automated still needs monitoring:

- Can fail
- Can be bypassed
- Logic outdated
- Testing required

Critical Trap

Automatedno equal Self-monitoring.

Q240: Control Testing Method

Question

BEST approach for testing?

A. Every transaction
B. Statistical sampling
C. Recent only
D. Management assurance

Q240: Explanation

Correct Answer: B

Statistical sampling:

- Practical
- Reasonable assurance
- Documented
- Defensible

Critical Trap

Testing = Sampling (not 100

Q241: Training Completion KPI

Question

Training completion percentage is:

A. KRI
B. KPI
C. KCI
D. None

Q241: Explanation

Correct Answer: B

KPI:

- Measures performance
- Backward-looking
- Not risk predictor
- Not control effectiveness

Critical Trap

Training completion = KPI. Phishing rate = KRI. Access review = KCI.

Q242: KRI Breach Action

Question

KRI breaches threshold. FIRST action?

A. Escalate
B. Investigate
C. Implement controls
D. Update register

Q242: Explanation

Correct Answer: B

Investigate:

- Data accuracy
- Spike or trend
- Root cause
- Response

Critical Trap

Investigate before acting.

Q243: Board Report Content

Question

What should NOT be in board report?

A. KRIs
B. Appetite comparison
C. Technical details
D. Actions

Q243: Explanation

Correct Answer: C

Technical details:

- Board not technical
- Focus business impact
- Technical obscures
- Strategic view needed

Critical Trap

Board = Business language.

Q244: SMART KRI

Question

"Number of incidents" weakness?

A. Not measurable
B. Lacks specificity and thresholds
C. Difficult
D. Irrelevant

Q244: Explanation

Correct Answer: B

Lacks specificity:

- What type?
- What severity?
- What timeframe?
- What triggers?

Critical Trap

Vague KRI = Useless KRI.

Q245: Control Monitoring Purpose

Question

PRIMARY purpose of monitoring?

A. Working as designed
B. Effectively reducing risk
C. Cost-effective
D. Automated

Q245: Explanation

Correct Answer: B

Effectively reducing risk:

- Workingno equal Effective
- Design flawed
- Threat changed
- Monitor effectiveness

Critical Trap

Workingno equal Effective.

Q246: Heat Map Limitation

Question

PRIMARY limitation?

- A Complex
- B Qualitative and subjective
- C Single risk
- D Data heavy

Q246: Explanation

Correct Answer: B

Qualitative and subjective:

- "High" varies
- No quantification
- Hard to compare
- Oversimplifies

Critical Trap

Heat map = Subjective.

Q247: Exception Report

Question

What should exception report include?

A. List only

B. Exception, controls, owner, expiration

C. Long-standing only

D. IT-approved only

Q247: Explanation

Correct Answer: B

Comprehensive:

- Description
- Compensating controls
- Risk owner
- Expiration
- Justification

Critical Trap

Exception reportno equal List.

Q248: Access Review KCI

Question

Access reviews completed on time is:

A. KRI
B. KPI
C. KCI
D. None

Q248: Explanation

Correct Answer: C

KCI:

- Access review = control
- Completion = effectiveness
- Not risk predictor
- Not performance

Critical Trap

Measures control = KCI.

Q249: Log Retention

Question

How long retain logs?

A. 30 days
B. 90 days
C. Regulatory and forensic
D. Indefinitely

Q249: Explanation

Correct Answer: C

Regulatory and forensic:

- Regulatory varies
- Forensic needs
- Storage costs
- Legal hold

Critical Trap

No universal period.

Q250: KRI Trend

Question

KRI trending up, below threshold. Action?

A. No action
B. Investigate and prepare
C. Wait
D. Escalate

Q250: Explanation

Correct Answer: B

Investigate:

- Trend indicates risk
- Threshold may breach
- Proactive action
- Understand cause

Critical Trap

Below threshold no equal No action.

Q251: Risk Response ROI

Question

Control costs $200K, reduces risk from $800K to $100K. ROI?

A. 100%

B. 200%

C. 250%

D. 300%

Q251: Explanation

Correct Answer: C

Calculation:

- Risk reduction = $700K
- Cost = $200K
- Net benefit = $500K
- ROI = $500K / $200K = 250%

Q252: Appetite Breach

Question

Appetite $100K. Current $150K. First action?

A. Accept
B. Reduce
C. Transfer
D. Escalate

Q252: Explanation

Correct Answer: B

Reduce:

- Exceeds appetite
- Bring within appetite
- Mitigate/transfer/avoid
- Escalate if cannot

Q253: Sample Size

Question

Minimum sample size?

A. 10
B. 25
C. Based on population and confidence
D. 100

Q253: Explanation

Correct Answer: C

Statistical:

- Population size
- Confidence level
- Statistical sampling
- Document

Q254: Authority Limits

Question

Can owner accept above authority?

A. Yes
B. No, escalate
C. With documentation
D. Below capacity

Q254: Explanation

Correct Answer: B

Escalate:

- Authority limits
- Above requires escalation
- Based on impact
- Higher approval

Q255: SOC 2 Scope

Question

SOC 2 covers 5 of 10 services. Action?

A. Rely on all
B. Assess out-of-scope
C. Reject
D. New report

Q255: Explanation

Correct Answer: B

Assess out-of-scope:

- Only scoped services
- Separate assessment
- Request expansion
- Document gap

Q256: Register Update

Question

How often update risk register?

A. Annually
B. When conditions change
C. Quarterly
D. Monthly

Q256: Explanation

Correct Answer: B

When conditions change:

- New risks
- Level changes
- Response implemented
- Owner changes

Q257: Deficiency Reporting

Question

Deficiency reported to FIRST?

A. Board
B. Risk owner
C. Auditors
D. IT

Q257: Explanation

Correct Answer: B

Risk owner:

- Accountable
- Budget authority
- Decides remediation
- Escalate if unresolved

Q258: Exception Approval

Question

Who approves exception?

A. IT
B. Business process owner
C. Risk manager
D. Affected

Q258: Explanation

Correct Answer: B

Business owner:

- Owns risk
- Budget authority
- Understands need
- Accountable

Q259: Response Documentation

Question

Why document responses?

- A Auditors
- B Due care evidence
- C Budget
- D Progress

Q259: Explanation

Correct Answer: B

Due care:

- Risk considered
- Accountability
- Protects legally
- Audit trail

Q260: Risk Velocity

Question

Risk velocity is:

A. Identification speed
B. Materialization speed
C. Implementation speed
D. Reporting speed

Q260: Explanation

Correct Answer: B

Materialization speed:

- High = Less time
- Monitoring frequency
- Risk appetite
- Urgency

Q261: KRI Trend

Question

KRI up 3 months below threshold. Action?

A. No action
B. Investigate and prepare
C. Wait
D. Board

Q261: Explanation

Correct Answer: B

Proactive:

- Trend indicates risk
- May breach
- Prepare
- Understand

Q262: Residual Acceptance

Question

Residual $300K, appetite $250K. Action?

A. Accept
B. Additional controls or escalate
C. Ignore
D. Remove

Q262: Explanation

Correct Answer: B

Action:

- Exceeds appetite
- Additional controls
- Escalate
- Cannot ignore

Q263: Test Exception

Question

1 exception in 100. Action?

A. Ignore
B. Investigate
C. Accept
D. Replace

Q263: Explanation

Correct Answer: B

Investigate:

- Cause
- Systemic or isolated
- Compensating
- 1

Q264: Appetite Authority

Question

Who accepts above appetite?

A. Owner
B. Control owner
C. Board
D. IT

Q264: Explanation

Correct Answer: C

Board:

- Sets appetite
- Approves exceptions
- Stakeholders
- Authority

Q265: Design Deficiency

Question

Control too complex, bypassed. This is:

A. Operating
B. Design
C. None
D. External

Q265: Explanation

Correct Answer: B

Design:

- Poor design
- Usability ignored
- Bypass predictable
- Balance needed

Q266: Register Critical

Question

Most important register element?

A. Description
B. Owner
C. Score
D. Plan

Q266: Explanation

Correct Answer: B

Owner:

- No owner = No accountability
- Others useless
- Owner drives
- Owner monitors

Q267: Vendor Assessment

Question

When vendor assessment?

A. Before contract
B. After
C. Go-live
D. Annually

Q267: Explanation

Correct Answer: A

Before:

- Negotiate
- Informed
- Deal-breakers
- Leverage

Q268: SOC 2 Type I

Question

Type I does NOT provide:

A. Design
B. Operating effectiveness
C. Description
D. Opinion

Q268: Explanation

Correct Answer: B

Operating effectiveness:

- Type I = Design
- Type II = Operating
- Type I snapshot
- Type II period

Q269: Response Selection

Question

Primary consideration?

A. Cost
B. Business objectives
C. Ease
D. Vendor

Q269: Explanation

Correct Answer: B

Objectives:

- Support goals
- Within appetite
- Cost secondary
- Effectiveness primary

Q270: KCI Definition

Question

KCI measures:

A. Risk
B. Performance
C. Control effectiveness
D. Value

Q270: Explanation

Correct Answer: C

Control effectiveness:

- Key Control Indicator
- Controls working
- Against tolerance
- Weaknesses

Q271: Heat Map vs Dashboard

Question

PRIMARY difference?

A. Visual

B. Dashboard combines quantitative and qualitative

C. Executive

D. IT

Q271: Explanation

Correct Answer: B

Dashboard combines:

- Heat map qualitative
- Dashboard both
- More flexible
- Trends

Q272: Exception Duration

Question

How long open?

- A Indefinite
- B Max 1 year, annual review
- C 30 days
- D Audit

Q272: Explanation

Correct Answer: B

Annual review:

- Verify need
- Compensating
- Close
- Re-approve

Q273: Control Testing

Question

Who tests?

A. Risk owner
B. Control owner
C. Audit
D. External

Q273: Explanation

Correct Answer: B

Control owner:

- Effectiveness
- Verify
- Audit independent
- External assurance

Q274: Owner Budget

Question

No budget consequence?

A. Not managed
B. Transfer
C. Avoid
D. Nothing

Q274: Explanation

Correct Answer: A

Not managed:

- No controls
- Unmanaged
- Ineffective
- Escalate

Q275: Velocity

Question

High velocity requires:

A. Less monitoring
B. More monitoring
C. No
D. Annual

Q275: Explanation

Correct Answer: B

More monitoring:

- Fast materialization
- Less time
- Real-time
- Frequent

Q276: Acceptance Doc

Question

What include?

A. Description only
B. Risk, justification, owner, review
C. Signature
D. Plan

Q276: Explanation

Correct Answer: B

Comprehensive:

- Description
- Justification
- Owner
- Review date
- Compensating

Q277: Implementation First

Question

First step?

A. Technology
B. Define objective
C. Train
D. Test

Q277: Explanation

Correct Answer: B

Define:

- Risk addressed
- Control achieve
- Requirements
- Select

Q278: Monitoring vs Audit

Question

Difference?

A. No
B. Monitoring continuous, audit periodic
C. Internal/external
D. Automated/manual

Q278: Explanation

Correct Answer: B

Continuous vs periodic:

- Monitoring ongoing
- Audit periodic
- Day-to-day
- Independent

Q279: KRI Effective

Question

What makes effective?

- A Easy
- B Actionable and predictive
- C Board
- D Automated

Q279: Explanation

Correct Answer: B

Actionable:

- Predicts
- Triggers action
- Relevant
- Proactive

Q280: Residual Definition

Question

Residual risk?

A. Before
B. After
C. Accepted
D. Transferred

Q280: Explanation

Correct Answer: B

After controls:

- Inherent - Control
- Remaining
- Within appetite
- Accepted

Q281: Multiple Controls

Question

How calculate residual?

A. Add
B. Sequential
C. Largest
D. Average

Q281: Explanation

Correct Answer: B

Sequential:

- Each reduces
- Apply in sequence
- Calculate after each
- Final result

Q282: Appetite Review

Question

How often?

A. Never
B. Annually or changes
C. 5 years
D. Breach

Q282: Explanation

Correct Answer: B

Annual:

- Minimum
- Strategy
- Market
- Incidents

Q283: Control Design First

Question

First consideration?

A. Cost
B. Risk
C. Technology
D. Convenience

Q283: Explanation

Correct Answer: B

Risk:

- Understand
- Design
- Cost secondary
- Means not end

Q284: Board Format

Question

Best format?

A. Technical
B. Executive summary
C. Full register
D. Raw

Q284: Explanation

Correct Answer: B

Executive:

- Concise
- Metrics
- Appetite
- Actions

Q285: Undocumented

Question

Undocumented acceptance?

A. Accepted
B. Not defensible
C. Transferred
D. Avoided

Q285: Explanation

Correct Answer: B

Not defensible:

- No due care
- No proof
- Negligence
- Challenge

Q286: Third-Party Monitor

Question

What monitor?

A. Contract
B. Security, incidents, compliance
C. Financial
D. SLA

Q286: Explanation

Correct Answer: B

Comprehensive:

- Security
- Incidents
- Compliance
- Financial
- SLA

Q287: Response Goal

Question

Ultimate goal?

A. Eliminate
B. Optimize
C. Auditors
D. Insurance

Q287: Explanation

Correct Answer: B

Optimize:

- Cannot eliminate
- Acceptable
- Enable
- Balance

Q288: Deficiency Report

Question

First report to?

A. Board
B. Risk owner
C. Auditors
D. IT

Q288: Explanation

Correct Answer: B

Owner:

- Accountable
- Budget
- Remediation
- Escalate

Q289: Register Update

Question

When update?

A. Annual
B. Change
C. Quarterly
D. Monthly

Q289: Explanation

Correct Answer: B

Change:

- New
- Level
- Response
- Owner

Q290: Delegation

Question

Required?

A. Verbal
B. Documented
C. None
D. Board

Q290: Explanation

Correct Answer: B

Documented:

- Formal
- Limits
- Communicated
- Trail

Q291: Vendor Exception

Question

Vendor requests exception?

A. Auto
B. Evaluate and compensate
C. Deny
D. Ignore

Q291: Explanation

Correct Answer: B

Evaluate:

- Need
- Risk
- Compensating
- Document

Q292: SOC 2 Scope

Question

All services?

A. Yes
B. Only scoped
C. Recent
D. Unreliable

Q292: Explanation

Correct Answer: B

Scoped:

- Specific
- Separate
- Check
- Expansion

Q293: Authority

Question

Above authority?

A. Yes
B. Escalate
C. Document
D. Capacity

Q293: Explanation

Correct Answer: B

Escalate:

- Limits
- Above
- Impact
- Approval

Q294: Testing Method

Question

Best?

A. All
B. Sampling
C. Recent
D. Assurance

Q294: Explanation

Correct Answer: B

Sampling:

- Practical
- Defensible
- Documented
- Repeatable

Q295: KRI Breach

Question

First?

- A Escalate
- B Investigate
- C Controls
- D Register

Q295: Explanation

Correct Answer: B

Investigate:

- Accuracy
- Spike
- Cause
- Response

Q296: Documentation

Question

Why?

A. Auditors
B. Due care
C. Budget
D. Progress

Q296: Explanation

Correct Answer: B

Due care:

- Considered
- Accountability
- Legal
- Trail

Q297: Velocity

Question

High requires:

A. Less
B. More monitoring
C. No
D. Annual

Q297: Explanation

Correct Answer: B

More:

- Fast
- Less time
- Real-time
- Frequent

Q298: Exception Review

Question

How often?

A. Never
B. Annual
C. 5 years
D. Breach

Q298: Explanation

Correct Answer: B

Annual:

- Verify
- Compensating
- Close
- Re-approve

Q299: Budget

Question

No budget?

- A Accept
- B Escalate
- C Ignore
- D Audit

Q299: Explanation

Correct Answer: B

Escalate:

- Budget
- Accountable
- Document
- Recommend

Q300: Final Goal

Question

Ultimate goal?

- A Eliminate
- B Optimize for objectives
- C Auditors
- D Insurance

Q300: Explanation

Correct Answer: B

Optimize:

- Cannot eliminate
- Acceptable
- Enable
- Balance

Final Wisdom

Risk management is not about eliminating risk.
It is about understanding risk and making informed decisions.
The goal is to optimize risk, not minimize it at all costs.

Final Summary

Key Takeaways for Domain C

- **Mitigate** = Reduce risk, not eliminate
- **Accept** = Formal, documented, informed
- **Transfer** = Financial shift only, accountability remains
- **Avoid** = Eliminate activity, opportunity cost
- **Risk Owner** = Business leader accountable
- **Control Owner** = Implementer of controls
- **KRI** = Predicts risk (forward-looking)
- **KPI** = Measures performance (backward-looking)
- **KCI** = Measures control effectiveness
- **Exceptions** = Annual review required
- **Vendor Risk** = Assess before contract
- **SOC 2** = Check scope first
- **Documentation** = Evidence of due care

Good Luck on Your CRISC Exam!

Remember: The ISACA mindset is about understanding why a question is asked, not just what is technically correct.

This completes 300 very hard Domain C questions.